

Project Sentinel — Inject 01: Engagement Plan (SOC)

FinServe Digital Bank Ltd · Sycom Consulting · Joint GRC/SOC plan, prepared by the SOC track · Sponsor: Priya Raman, CISO · v1.0, Tue 6 Oct (W1 D1)

Objective. Answer the CISO’s question — “What would FinServe actually see?” — by testing where security telemetry, Sentinel detection and investigation lookback actually exist across the estate, and give the week-4 board a consequence-ranked list of blind spots: what to fix first and what happens if it is not fixed. The GRC track establishes what FinServe has, what it is worth, what could go wrong and which third parties hold its data; the two views are joined at three comparison points (§2).

1 SCOPE

Area	In scope (SOC unless stated)
Microsoft Sentinel	Workspace law-sentinel-prod (sub-management): data connectors, ingestion health, per-table retention (60-day default), analytics rules (Microsoft templates + 4 custom KQL rules), automation, incident handling (847 alerts in 30 days, two-person rota, no out-of-hours cover).
Azure	All six subscriptions, including sub-sandbox (Activity Log only, 14 standing Owners) and sub-nonprod (sqlldb-uat holds unmasked production D3 and NI numbers; CHG-2024-0881 path to sqlmi-prod). Production: AKS, App Service, APIM, Functions, SQL MI audit, Storage stfinserve-docs, Key Vault, Firewall/WAF, VPN.
Identity and privileged activity	Entra ID sign-in/audit; CA-Exclusions-Service (break-glass, 3 service accounts, FinRecon IMAP basic-auth mailbox); standing Owner/Contributor (PIM not configured); AD Domain Admins (6); JUMP-01; Entra Connect; pipeline service principals.
M365 and endpoint	Unified Audit Log (90 days E3/F3 vs 180 days E5), Defender for Office 365, Defender for Endpoint (30-day raw), Intune audit (not forwarded), BYOD (identity telemetry only).
Legacy, network and third-party paths	DC-SLO (11 workloads; Fortigate to Sentinel; SFTP server logs local only, 30 days); branch firewalls (local, 14 days; split tunnelling). FinServe-side visibility of Corebridge (logs by ticket), the Meridian Trust settlement path (P8/F7–F9), FinRecon/Solvex remote support, Textway and IDVerify.
Business lens (joint)	IBS-1 to IBS-5 and their impact tolerances, plus P8 settlement (not an IBS, but carries D3 through DC-SLO unattended). GRC: asset, data (D1–D7, F1–F10), risk and supplier registers built from the architecture, not the untrusted registers.

Out of scope. Penetration testing, red teaming or generating test events in production (unless the CISO approves a specific benign test in writing) · changing any configuration, connector, rule, retention or access setting (we recommend; FinServe implements) · a compromise assessment or historical threat hunt (anything suspicious found incidentally is escalated, not investigated by us) · assurance of third parties’ own controls and any direct contact with them (requests go via the mentor) · DR/failover testing, PCI DSS re-scoping and legal opinions on transfers (GRC records these as risks only).

2 APPROACH

SOC workstream. “Sentinel is fully deployed” is a claim to test, not a starting assumption. Every item is labelled **Verified** (seen in the tenant), **Lead** (documented, not yet tested) or **Not determinable**. Only Verified items reach the board as findings.

Step (week)	What we do
1 Map (W1)	Trace IBS → system → identity → expected log source from 02-ARCHITECTURE. Record where the documents disagree, e.g. AKS logs “onboarded” (network doc) vs “AKS audit not enabled” (Azure doc), or “all diagnostics” vs Storage diagnostics off.
2 Validate ingestion (W1–W2)	Read-only KQL on law-sentinel-prod (Usage, table last-seen, Heartbeat) plus diagnostic-setting and DCR exports: does each source arrive, with which fields, for how long, and is it usable for investigation?
3 Assess detection (W2)	Review every analytics rule (enabled, logic, frequency, last fired) and how the 847 alerts were handled. Map coverage to ATT&CK and to FinServe scenarios: privileged misuse, CA-exclusion abuse, D2/D3 data access, settlement-path tampering, sandbox/non-prod pivot.
4 Lookback and time to detect (W3)	For each source, how far back an investigator can see (14 days branch → 30 days AKS/MDE → 60 days Sentinel → 1 year SQL audit outside the SIEM), and a realistic time to detect given no out-of-hours rota.
5 Rank and report (W3–W4)	With GRC, rank blind spots by consequence. Each gap is written as evidence → consequence → fix → owner, in board language.

GRC workstream. Builds the asset, data-flow, risk and supplier registers from the architecture (Solvex is missing from the supplier register; Textway has no DPA), and rates consequence against impact tolerances and PRA/FCA/UK GDPR obligations.

SOC/GRC comparison points.

- **CP1 — Fri 16 Oct.** GRC asset/IBS and data map vs SOC telemetry coverage: every asset holding D2/D3/D7 or supporting an IBS needs a working log source. A mismatch is either a blind spot or a register error.
- **CP2 — Wed 21 Oct.** GRC supplier and data-flow register vs third-party investigation visibility: for F2 and F5–F9, can FinServe reconstruct activity, and how fast (Corebridge ticket turnaround, local SFTP logs, Solvex sessions)?
- **CP3 — Fri 23 Oct.** GRC risk ratings vs SOC detection gaps and lookback: a high-consequence risk with no detection and a short lookback goes to the top of the board list.

Early escalation. We escalate the same working day, in writing, to Priya Raman (copied to the engagement lead), and do not hold anything for week 4. Triggers are: indicators of active compromise; an exposed or unrotated credential in use on a critical path (e.g. the static Meridian Trust SFTP credential, once verified); confirmed absence of telemetry for an IBS or a Restricted data store; or anything likely to require PRA, FCA or ICO notification. There is also a CISO checkpoint every Friday (9, 16 and 23 Oct).

3 ASSUMPTIONS AND DEPENDENCIES

Assumptions. A1 Architecture documents (reviewed Aug–Nov 2025) describe intended state; every statement is a claim to verify. A2 Read-only access; the team makes no production changes. A3 There is no known incident at start (CISO engagement letter). A4 No access has been granted yet. A5 Questions and third-party requests are answered via the mentor within one working day. A6 Day numbering runs from W1 D1 = Tue 6 Oct, five working days a week, so W4 D3 = Thu 29 Oct; the 00-ADMIN schedule was not supplied, so please confirm (Q1).

#	Dependency	Provider	Needed by
D1	Microsoft Sentinel Reader + Log Analytics Reader on law-sentinel-prod (sub-management)	M. Ifill / A. Balogun	Wed 7 Oct
D2	Reader on all six subscriptions (incl. sub-sandbox, sub-nonprod), including diagnostic settings and Azure Policy assignments	A. Balogun	Wed 7 Oct
D3	Entra ID Global Reader; read-only Defender XDR and Purview audit search	F. Adeyemi	Thu 8 Oct
D4	Exports: analytics and automation rules (incl. disabled), connector status, DCRs (JUMP-01, DCs), per-table retention, 30-day incident list	M. Ifill	Thu 8 Oct
D5	90-min Slough session with T. Okonkwo (leaves in ~8 weeks; R-11 key person): the 11 workloads, their log paths, SFTP and branch firewall config	T. Okonkwo	Fri 9 Oct
D6	60-min sessions: Sentinel operations (M. Ifill), Azure platform (A. Balogun), M365/endpoint (F. Adeyemi)	Named SMEs	7, 8, 12 Oct
D7	7-day log samples: DC-SLO SFTP syslog and one branch firewall	T. Okonkwo	Tue 13 Oct
D8	Corebridge ticket (raised via mentor Thu 8 Oct): available log types, retention, turnaround, one sample	Mentor / Corebridge	Tue 20 Oct
D9	GRC draft asset, IBS and data-flow mapping for CP1	GRC track	Thu 15 Oct

4 QUESTIONS FOR FINSERVE

#	Question	Why it matters
Q1	What is the date and time of the week-4 board session, and how long is our slot? Is W4 D3 = Thu 29 Oct correct?	Sets the back-schedule; not stated in 01/02
Q2	Which 11 workloads remain in DC-SLO, and which (other than Fortigate) send logs to Sentinel or run MDE/AMA?	The architecture names only Fortigate and SFTP; this is the largest unknown on the detection surface
Q3	Which AKS diagnostic categories are enabled (kube-audit / kube-audit-admin vs container logs)?	The network and Azure documents contradict each other
Q4	Are diagnostic settings enforced by Azure Policy, and which resource types are excluded (Key Vault, APIM, Functions, Redis)?	"All resource diagnostics" conflicts with Storage diagnostics being off
Q5	Are servers (JUMP-01, DCs, Entra Connect, DC-SLO hosts) onboarded to Defender for Endpoint/Servers? Is Defender for Identity deployed?	The documents cover corporate laptops only; Defender for Cloud plan coverage is unstated

Q6	Is there any MSSP/MDR or Defender Experts support? What happens to a high-severity alert out of hours if M. Ifill is unavailable?	Determines realistic time to detect
Q7	What does the Corebridge contract provide: log types (admin, auth, API, transaction audit), retention, ticket turnaround, security-event notification?	Retention is recorded only as "per contract"
Q8	How does Solvex connect for remote support (tool, account, approval, session logging)?	Third-party access to D3 that is not documented
Q9	Which investigations in the last 12 months were limited by missing logs or retention?	Grounds the lookback analysis in real cases

5 DELIVERABLES AND DATES

Date	Wk/Day	Deliverable / milestone	Lead
Tue 6 Oct	W1 D1	Engagement plan and questions issued; access requests D1–D4 raised	Joint
Wed 7 Oct	W1 D2	Access confirmed; Sentinel operating walkthrough (847 alerts, rota)	SOC
Thu 8 Oct	W1 D3	Configuration exports received; Azure platform session; Corebridge log request raised	SOC
Fri 9 Oct	W1 D4	Slough SME session (T. Okonkwo); CISO checkpoint 1	SOC
Thu 15 Oct	W2 D3	Detection surface v1: log-source inventory and ingestion validation	SOC
Fri 16 Oct	W2 D4	CP1 : verified coverage gaps and analytics-rule review; CISO checkpoint 2	Joint
Wed 21 Oct	W3 D2	CP2 : supplier and data-path visibility (Corebridge, SFTP/Meridian, Solvex, Textway)	Joint
Thu 22 Oct	W3 D3	Lookback and time-to-detect analysis per IBS	SOC
Fri 23 Oct	W3 D4	CP3 : consequence-ranked detection gap analysis; emerging-findings brief to CISO; checkpoint 3	Joint
Tue 27 Oct	W4 D1	SOC section of the joint board pack, with evidence log	SOC
Wed 28 Oct	W4 D2	QA: every finding traced to Verified evidence; senior consultant review	Joint
Thu 29 Oct	W4 D3	Board pack to CISO, 09:00 (she will not edit it)	Joint
TBC (Q1)	W4	Board session: Chair, 4 NEDs, CEO, CISO	Joint
Any day	—	Early escalation to CISO, same working day, in writing (§2)	SOC